Laporan Kerentanan Keamanan

Responsible Disclosure — publicly redacted version

Informasi Temuan

Judul	Broken Access Control (IDOR) pada Sistem Informasi Magang Mahasiswa
Tanggal Temuan	17 Juni 2026
Ditemukan Oleh	Alexander Agung Raya
Tingkat Risiko	High / Critical

Ringkasan

Ditemukan kerentanan **Broken Access Control (IDOR)** pada modul pendaftaran magang. Pengguna yang telah login dapat mengakses data mahasiswa lain hanya dengan mengubah parameter ID pada URL.

Data yang dapat diakses meliputi:

- Nama Mahasiswa
- NIM
- NIK
- IPK
- Jurusan
- Program Studi
- Kota/Kabupaten
- Dokumen Pendukung
- Informasi Perusahaan Magang

URL Terdampak

Contoh:

`https://[REDACTED]/mw/pendaftar/proses/pr1/[ID_XXXXX]`

Ketika parameter diubah menjadi:

`https://[REDACTED]/mw/pendaftar/proses/pr1/[ID_YYYYY]`

sistem menampilkan data mahasiswa lain.

Langkah Reproduksi

1. Login menggunakan akun mahasiswa yang sah.
2. Buka halaman data magang pribadi: `https://[REDACTED]/mw/pendaftar/proses/pr1/[ID_XXXXX]`
3. Ubah ID pada URL menjadi ID lain. Contoh: `https://[REDACTED]/mw/pendaftar/proses/pr1/[ID_YYYYY]`
4. Tekan Enter.

Hasil Aktual: Data mahasiswa lain dapat diakses.

Hasil Yang Diharapkan — sistem harus:

- Menolak akses (403 Forbidden), atau
- Menampilkan halaman tidak ditemukan (404), atau
- Memastikan hanya pemilik data yang dapat mengakses data tersebut.

Dampak

Potensi kebocoran data pribadi mahasiswa:

- Nama, NIM, NIK
- Informasi akademik
- Dokumen pendukung

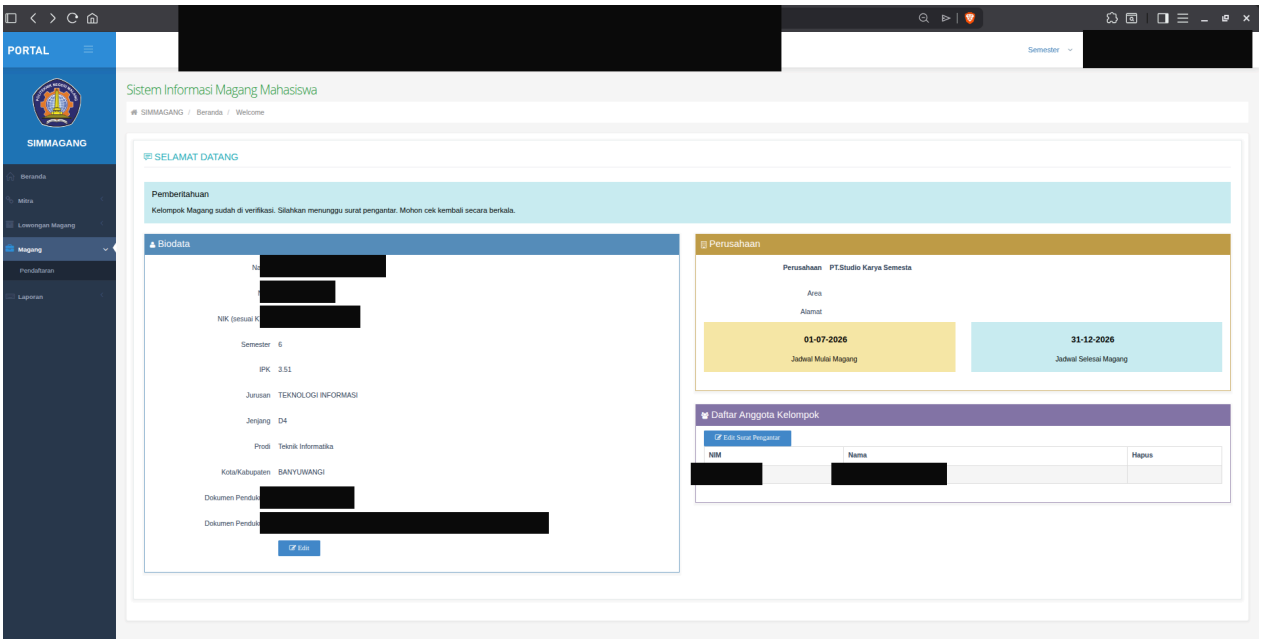
Jika fungsi edit dapat digunakan, maka penyerang juga berpotensi:

- Mengubah data mahasiswa lain
- Mengganti dokumen
- Merusak integritas data magang

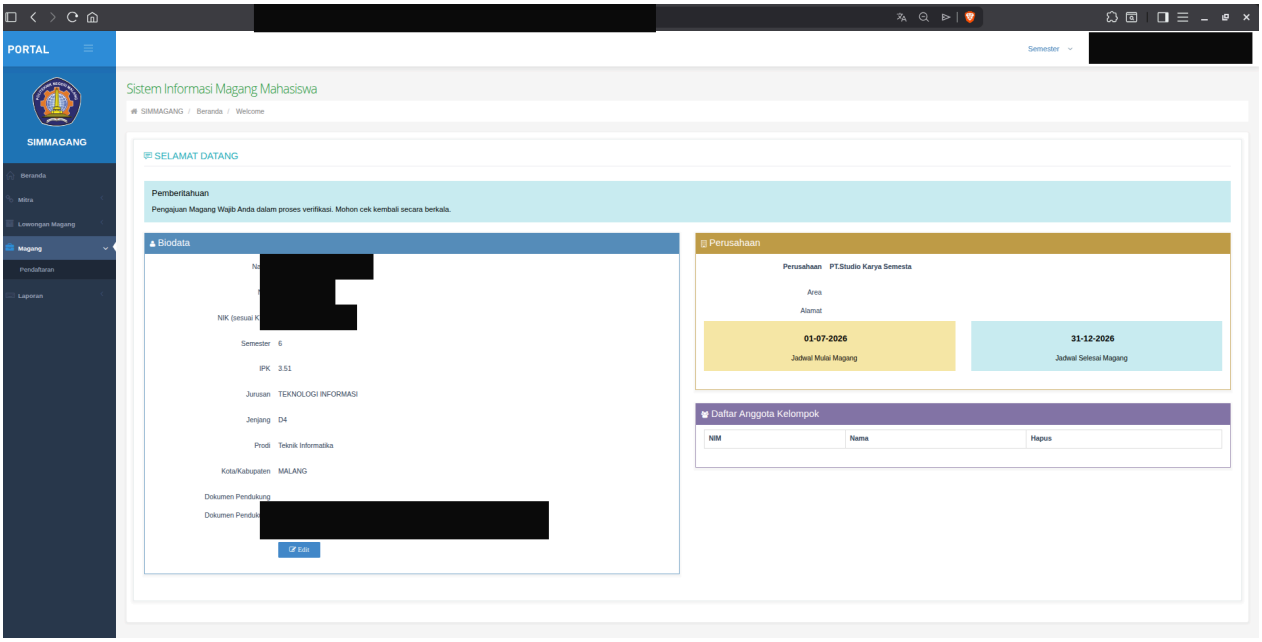
Bukti

Catatan redaksi: URL pada address bar, NIK, NIM, nama, kontak, dan tautan dokumen telah disensor untuk publikasi.

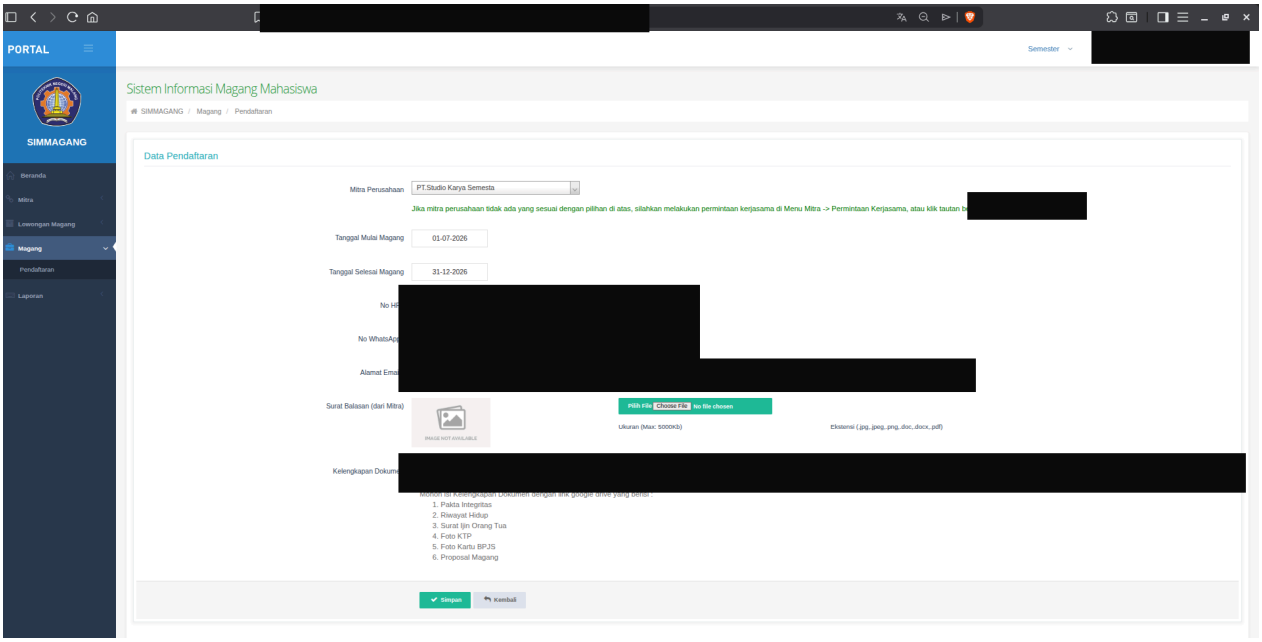
Screenshot 1 — Data milik sendiri.



Screenshot 2 — Data milik mahasiswa lain setelah mengganti ID URL.



Screenshot 3 — Tombol Edit yang muncul pada data mahasiswa lain.



Rekomendasi

Backend harus melakukan pengecekan kepemilikan data sebelum menampilkan atau mengubah data. Contoh logika:

```
if ($magang->user_id != auth()->id()) {
    abort(403);
}
```

atau

```
if ($magang->nim != session('nim')) {
    abort(403);
}
```

Klasifikasi

- **CWE-639**: Authorization Bypass Through User-Controlled Key
- **Kategori**: IDOR (Insecure Direct Object Reference)
- **OWASP A01**: Broken Access Control

Impact Summary

Penyerang yang telah login sebagai mahasiswa dapat mengakses data mahasiswa lain tanpa izin dengan memodifikasi parameter pada URL. Data yang dapat terekspos meliputi: NIK, NIM, data akademik, dokumen pendukung, dan informasi magang.

Kesimpulan

Ditemukan kerentanan Broken Access Control (IDOR) yang memungkinkan pengguna yang terautentikasi mengakses data mahasiswa lain dengan mengubah parameter URL. Disarankan agar sistem menerapkan pemeriksaan otorisasi pada setiap akses data mahasiswa untuk mencegah akses tidak sah.